

COMPX304-23A

Advanced Networking and Cybersecurity

Week 7
Introduction to Cyber Security

Vimal Kumar

Slides: Vimal Kumar, Chris Anderson, Panos Patros



Cyber Security

- This course is an overview of Cybersecurity
 - There are a lot of specialisations in the field
- Many solutions are dependent on risk appetite
 - More on this later



Cyber Security

- Background
 - Our systems are connected to networks
 - Can we assume they're operating within normal parameters?
 - Particularly, when adversaries are present?
- Key requirements (CIA):
 - Confidentiality
 - Integrity
 - Availability



Key Requirements: CIA

- Confidentiality
 - Information/functionality is selectively disclosed
 - Example Failure: The balance of an account is made available to the wrong person
- Integrity
 - Information/functionality is selectively modifiable
 - Example Failure: Someone else changes your account
- Availability
 - Information/functionality is available/usable to its intended users
 - Example Failure: Getting a timeout while trying to pay with EFTPOS



Terminology [ISO/IEC 27000]

- **Attack:** *“attempt to destroy, expose, alter, disable, steal or gain unauthorized access to or make unauthorized use of an asset”*
- **Threat:** *“potential cause of an unwanted incident, which can result in harm to a system or organization”*
- **Vulnerability:** *“**weakness of an asset or control** that can be exploited by one or more threats”*

Vulnerabilities are enumerated in Mitre’s CVE database

<https://www.iso.org/obp/ui/#iso:std:iso-iec:27000:ed-5:v1:en>



Additional Terminology

Weakness: *“A fundamental flaw, fault, bug, or other error in implementation, code, design, or architecture that could result give rise to a vulnerability.”*

For example:

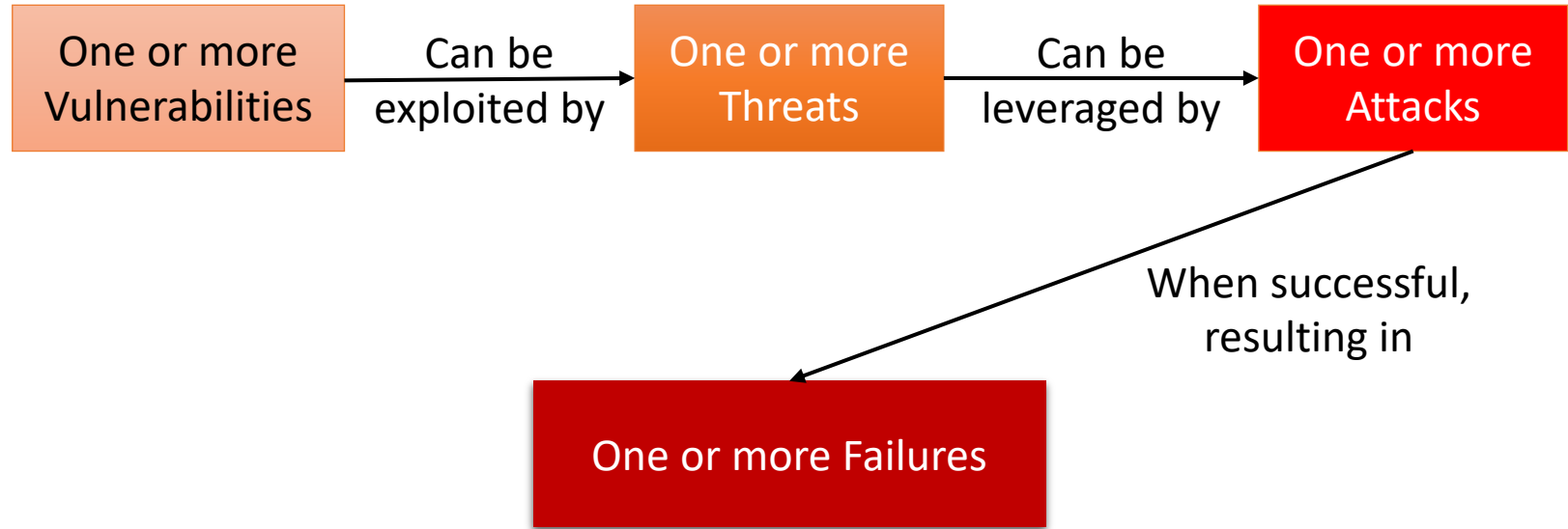
- Incorrect bounds checking
- Implicitly trusted input parameters

Not necessarily an issue, yet.

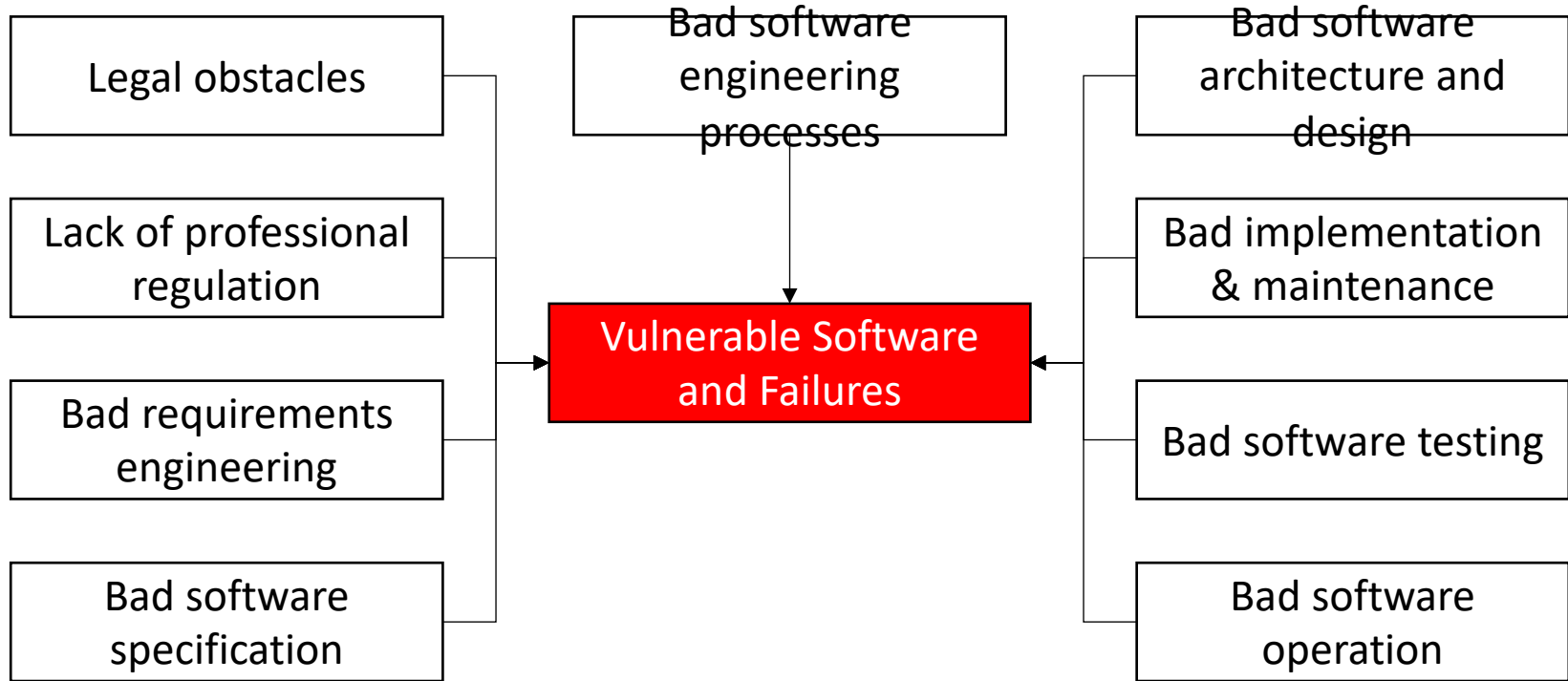
Enumerated in Mitre CWE database



Breaking it down



Common sources of vulnerabilities



Security = Minimising Risk

- Backups
 - Planned
 - Tested
- Incident Response
 - Who needs to be told
 - + more
- Procedural Guidelines
 - What needs done



Bird's eye view

Software applications

Operating System

Physical Hardware



Social Engineering

- Engineering is for the people
 - Which is sometimes forgotten...
 - Or taken advantage of
- Psychological manipulation
- People can be tricked
- Example
 - Donning a hi-vis vest, holding a hot beverage and a clipboard, and pressing a phone to your ear will get one into many places one shouldn't be.

<https://www.youtube.com/watch?v=NiEMcjSQOzg>



Social Engineering: Example Vulnerabilities

- People feel like
 - Returning a favour
 - Following through to a commitment
 - Acting similarly to others around them
 - Respecting authority figures
 - Accepting to do what people they like tell them to do
 - Taking advantage of opportunities
 - Rare or one-off
 - Discount



Social Engineering

- To reiterate and things to :
 - Urgency
 - Quid pro quo
 - Status Quo
 - Kindness
 - Authority



Professional Ethics!

- Remember!
- As professional Software Engineers and Computer Scientists
- You must not use this information to take advantage of people



Social Engineering: Example Attack Vectors

- Phishing
 - Legit appearing email to divulge personal information
 - E.g., redirects to a fake website where user logs in
 - **Spear phishing**: Highly customized to specific target
- Vishing
 - Similar but over the phone
- Smishing
 - Similar but via SMS
- Impersonation



Social Engineering: Example Attack Vectors

- Water holing
 - Set a trap in a usually visited website
 - People are relaxed vs. receiving a phishing email
- Baiting
 - Infected USB Keys, CDs, etc. with attractive titles
 - <https://www.youtube.com/watch?v=ZI5fvU5QKwQ>
- Quid pro quo
 - “I won’t need to wipe the phone to repair it if you give me the password”
- Tailgating/piggybacking
 - Run behind someone after they get access to a building



Social Engineering: Example Attack Vectors

- Shoulder surfing
 - Reading PINs or Passwords from people as they enter them
- Dumpster Diving
 - Literally as the name suggests
 - Documents that can be used to impersonate
 - Incorrectly disposed information
 - Unwiped or undestroyed storage



Professional Ethics!

- Remember!
- As professional Software Engineers and Computer Scientists
- You must not use this information to take advantage of people



Social Engineering: Countermeasure examples

- Don't open suspicious emails and attachments
- Multifactor authentication
- Don't trust tempting offers
- Don't give personal information online, over the phone, SMS,...
- Tell them you'll call them back and look up their number
- Be mindful of online-only friends
- Keep your software updated
- Maintain a cyber security awareness culture



Cyber attacks

- A large percentage (~80%) of cyberattacks start with social engineering.
 - Phishing
 - Spear Phishing
 - Dumpster diving etc.
- Usually the goal is to obtain a user's credentials to get into an enterprise network first. Once entry is gained attackers further exploit software and hardware vulnerabilities to gain privileges.



Social Engineering

- Exploits inherent vulnerabilities in humans
- Human vulnerabilities are harder to fix than software/hardware vulnerabilities
- How do we deal with vulnerabilities?
 - Find the vulnerability
 - Find the cause of the vulnerability
 - Create a solution to fix the vulnerability
- We often time have limited control over human weaknesses/vulnerabilities



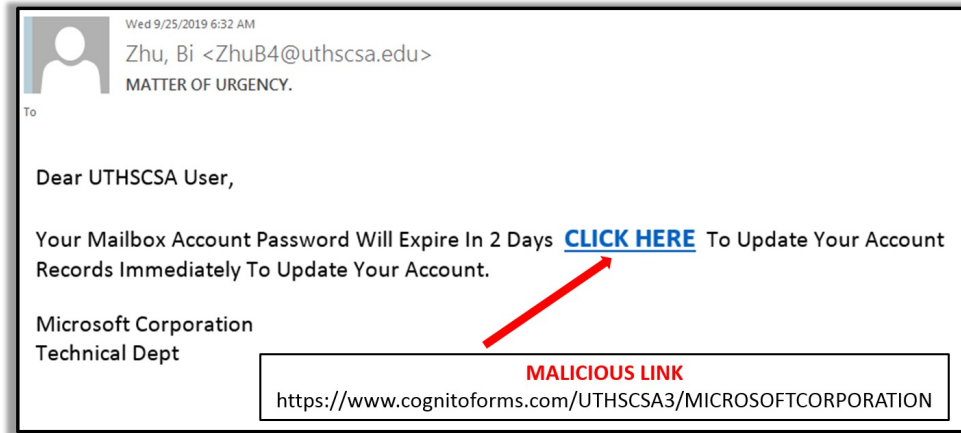
Social Engineering

- Uses psychology either explicitly or implicitly
- Example
 - Amygdala
 - Amygdala is a small part of our brain which processes and triggers strong emotions and the fight and flight response
 - Cortex
 - Cortex is the part of the brain that develops a logical response
 - In the event of a threat the Amygdala processes sensory information and prepares a response that may help a human evade the threat
 - The cortex takes times to process the information and develop a logical response

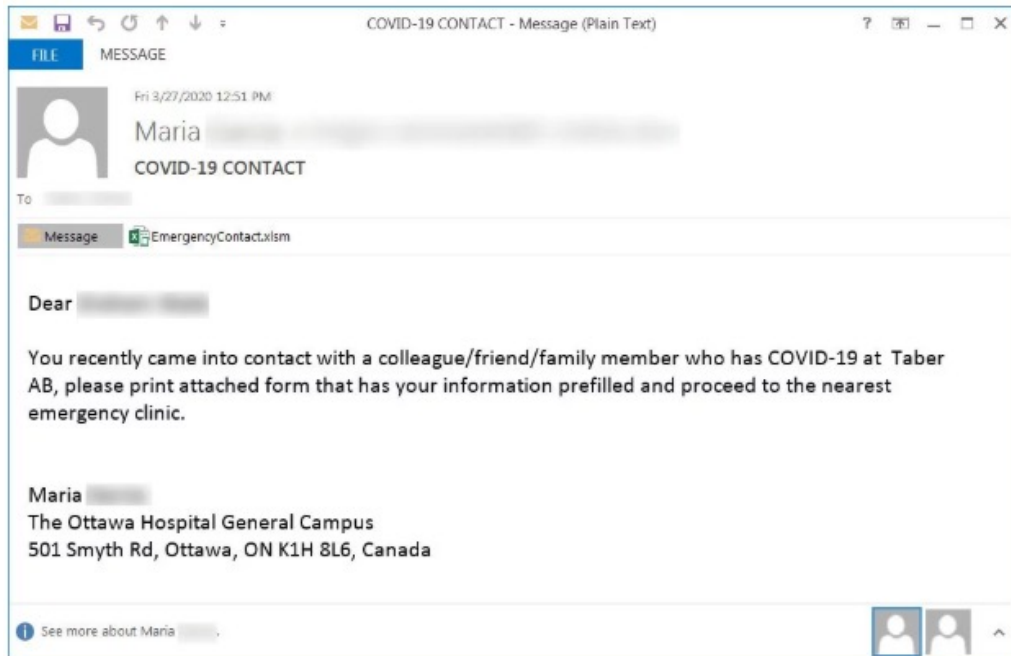


Urgency

- Attackers want the victim to take an action in a heightened emotional state



Fear

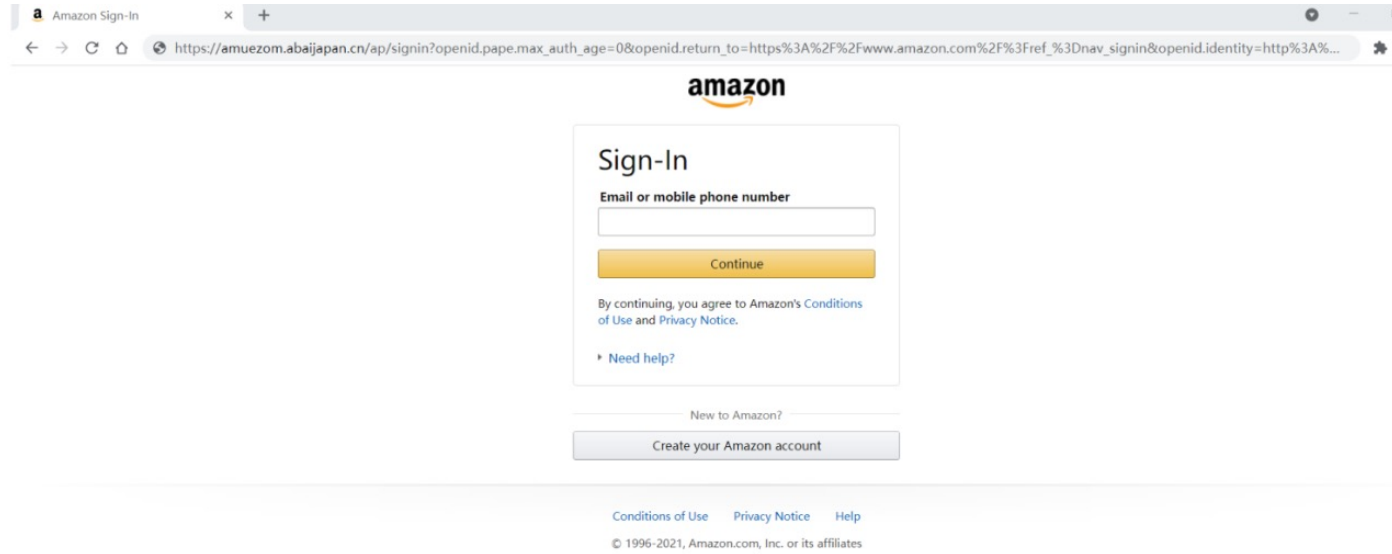


Curiosity



Social Engineering

- Attackers exploit trust and the need to feel trusted.



Social Engineering - Homographs

apple.com

apple.com



Social Engineering: Countermeasure examples

- Don't open suspicious emails and attachments
- Multifactor authentication
- Don't trust tempting offers
- Don't give personal information online, over the phone, SMS,...
- Tell them you'll call them back and look up their number
- Be mindful of online-only friends
- Keep your software updated
- Maintain a cyber security awareness culture

